Dunder Mifflin Paper Company Vulnerability Scan Report

Executive Summary

In September 2024, Dunder Mifflin Paper Company engaged JHConsulting to conduct a comprehensive penetration test of its network infrastructure, prompted by an evolving cybersecurity landscape and the need to proactively safeguard critical assets. Our objective was to identify vulnerabilities within the network that could expose the organization to potential cyber threats, ensuring that Dunder Mifflin remains resilient against advanced attacks. This assessment focused on pinpointing security gaps across key systems and providing actionable recommendations to enhance defenses. The engagement uncovered several critical and high-severity vulnerabilities, including remote code execution risks and configuration weaknesses, underscoring the importance of ongoing vigilance and regular security reviews.

1. Vulnerability Summary

The following vulnerabilities were identified in Dunder Mifflin's network. Each vulnerability is categorized based on its potential risk impact and the specific hosts affected.

1.1 PHPFusion 9.03.50 Remote Code Execution

- **Hostname**: nyc-web1
- **Vulnerability Name**: PHPFusion 9.03.50 Remote Code Execution
- **Author**: geeknik
- **Severity**: High

- **Description**: This vulnerability allows an authenticated user with non-admin privileges to escalate privileges via a crafted request, enabling remote command execution (RCE) on the server. Successful exploitation can lead to arbitrary code execution.
- **Reference**: PHPFusion 9.03.50 Remote Code Execution
- **Tags**: cve, cve2020, phpfusion, rce
- **Recommendation**: Update PHPFusion to the latest patched version and restrict access to trusted users only. Additionally, monitor the server for any suspicious activity from non-admin accounts.

1.2 CVE-2022-41040 - ProxyNotShell Vulnerability Chain

- **Hostname**: mail
- **Vulnerability Name**: ProxyNotShell (CVE-2022-41040 and CVE-2022-41082)
- **Severity**: Critical
- **Description**: ProxyNotShell is a chain of vulnerabilities affecting Microsoft Exchange email servers. It includes:
- **CVE-2022-41040**: A Server-Side Request Forgery (SSRF) vulnerability, allowing an authenticated attacker to remotely exploit the second vulnerability in this chain.
- **CVE-2022-41082**: A Remote Code Execution (RCE) vulnerability exploitable when PowerShell is accessible, allowing the attacker to gain control over the Exchange server.

Since these vulnerabilities require only authenticated access and can provide full control of the Exchange server, they pose a critical risk. CISA has listed these vulnerabilities as known exploited, indicating active exploitation in the wild.

- **Recommendation**: Apply the latest patches provided by Microsoft to address the ProxyNotShell vulnerabilities. Limit access to PowerShell on the Exchange server to trusted administrators and monitor for any signs of SSRF or RCE attempts.

1.3 CVE-2023-29974 - Weak Password Requirements in pfSense

- **Hostname**: pfsense
- **Vulnerability Name**: Weak Password Requirements in pfSense CE 2.6.0
- **Severity**: High
- **Description**: An issue in pfSense CE version 2.6.0 allows attackers to compromise user accounts through weak password requirements. This vulnerability weakens password strength policies, making user accounts more susceptible to brute-force attacks.
- **Recommendation**: Upgrade pfSense to the latest version, which enforces stronger password policies. In the meantime, implement strict password policies to ensure high password complexity requirements. Additionally, consider enabling account lockout policies to mitigate brute-force attack risks.

2. General Recommendations

- Regularly review and update all systems to ensure they are patched against known vulnerabilities.
- Strengthen password policies and enforce multi-factor authentication (MFA) where possible.
- Limit exposure of critical services to reduce the attack surface and implement monitoring for unauthorized access attempts.
- Conduct regular security assessments to identify and mitigate emerging vulnerabilities promptly.

This report provides an overview of the vulnerabilities identified and initial recommendations for remediation. Further analysis may be required for comprehensive mitigation.